COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.1 · Security Policies

Mestre CyberSec · **Lesson 5.1 — Security Policies** (11:02) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Policies = o QUE deve ser feito (top-level); Standards = o HOW (mais técnico); Procedures = o passo-a-passo. AUP (acceptable use policy): o que o usuário pode fazer. BCP (business continuity plan)/DRP (disaster recovery plan) = continuidade do negócio.

💡 Key Exam Highlights & Critical Concepts

- Policy: o 'o quê'. Standard: o 'como'. Procedure: o passo-a-passo
- AUP: o que o usuário PODE fazer com recurso corporativo

🎯 Exam Tips & Typical CompTIA Scenarios

- 'high-level document stating what to protect'=policy

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.1 — Security Policies)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Policy (N/A)

A high-level, mandatory document that states what an organization wants to protect and its overall security objectives; it does not specify technical implementation.

⚠️ ***Exam Trap:*** *Se a questão pedir 'high-level document stating what to protect', a resposta é policy. Não confunda com standard (como) ou procedure (passo a passo).*

• Standard (N/A)

A mandatory, technical document that defines specific requirements, rules, or baselines for implementing a policy.

⚠️ ***Exam Trap:*** *Standard = 'como' técnico e mensurável. Se a questão citar configuração específica, criptografia AES-256 ou senha mínima, provavelmente é standard.*

• Procedure (N/A)

A mandatory, step-by-step document that describes exactly how to perform a specific task or process in accordance with policies and standards.

⚠️ ***Exam Trap:*** *Procedure = passo a passo operacional. Se a questão descreve uma sequência de ações a serem executadas, é procedure.*

• Guidelines (N/A)

Non-mandatory recommendations or best practices that help users and administrators comply with policies and standards.

⚠️ ***Exam Trap:*** *Guidelines são recomendadas, mas não obrigatórias. Se a questão disser 'best practice' ou 'não obrigatório', não é policy nem standard.*

• Acceptable Use Policy (AUP)

A policy that defines what users are permitted and not permitted to do with corporate IT resources, including email, internet, and devices.

⚠️ ***Exam Trap:*** *AUP = o que o usuário PODE fazer com recurso corporativo. Frequentemente exige assinatura ou ciência do funcionário. Não é BCP nem DRP.*

• **Business Continuity Plan (BCP)**
A plan that ensures critical business functions can continue during and after a disruption, focusing on the entire organization's resilience.

⚠️ ***Exam Trap:*** *BCP = continuidade do negócio como um todo. Se a questão fala em manter operações críticas durante um desastre, é BCP. DRP é recuperação de TI.*

• **Disaster Recovery Plan (DRP)**
A plan focused on recovering IT infrastructure, systems, and data after a disaster, including restoration procedures and recovery time objectives.

⚠️ ***Exam Trap:*** *DRP = recuperação técnica de TI após desastre. Não confunda com BCP, que é mais amplo e focado no negócio. DRP costuma vir após o BCP.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Governance Hierarchy: Security Policies

🏠 **Real-World Analogy:** A nation's constitution or corporate charter. It defines high-level principles, core rights, fundamental duties, and leadership commitment, stating WHAT must be secured and why, without specifying low-level technical brands, cable specs, or configuration screens.

🔍 **Root Cause & Background:** Without executive-mandated strategic direction, departments create conflicting, ad-hoc safety practices, creating compliance loopholes, wasted capital, and legal inability to hold negligent users accountable.

🛡️ **GRC Auditor Perspective:** Audit policy governance: verify formal C-level/Board sign-off, versioning lifecycle, mandatory annual reviews, and signed user acknowledgment agreements upon hire.

⚠️ **How CompTIA Tests This:** Exam trigger: 'high-level document created by senior management defining overall security goals and strategic intent' = Security Policy. Distractor: do not confuse with Standard (technical mandatory baseline) or Procedure (step-by-step SOP).

📌 Acceptable Use Policy (AUP)

🏠 **Real-World Analogy:** A company vehicle rental agreement: it explicitly specifies that the car may be driven for business tasks and client visits, but strictly bans street racing, hazardous material transport, or handing keys to unauthorized strangers, while declaring active GPS monitoring.

🔍 **Root Cause & Background:** Employees frequently misuse corporate assets and email for peer-to-peer piracy, gaming, gambling, or moonlighting ventures, exposing the company to malware epidemics, legal liability, and data theft.

🛡️ **GRC Auditor Perspective:** Confirm that the AUP explicitly bans illegal usage and commercial side-businesses, establishes zero expectation of personal privacy on corporate systems, and is signed before credentials are issued.

⚠️ **How CompTIA Tests This:** Exam trigger: 'document that an employee must sign detailing what they are permitted and forbidden to do with corporate IT assets' = Acceptable Use Policy (AUP).

📌 Clean Desk & Clear Screen Policy

🏠 **Real-World Analogy:** Locking your checkbooks, credit cards, and private journals into a desk drawer before leaving a hotel room, and closing the blinds. Leaving passwords and customer reports in plain sight allows visiting contractors, janitors, or delivery couriers to harvest confidential data at a glance.

🔍 **Root Cause & Background:** The common human habit of sticking credential post-its onto monitors, leaving printed PII sitting in shared printer trays, and walking away to lunch with unlocked desktop workstations.

🛡️ **GRC Auditor Perspective:** Perform unannounced after-hours physical desk sweeps, enforce automated screen lockouts via GPO/MDM after 5-10 minutes of inactivity, and verify locked shredding bins for confidential hard copies.

⚠️ **How CompTIA Tests This:** Exam trigger: 'reduce the risk of shoulder surfing, unauthorized physical document viewing, or credentials on sticky notes' = Clean Desk / Clean Screen Policy.

📌 Bring Your Own Device (BYOD) Policy

🏠 **Real-World Analogy:** A strict condominium rule letting residents install personal grills on balconies, provided they install an approved fire extinguisher, respect quiet hours, and grant the building inspector the right to check gas lines at any time.

🔍 **Root Cause & Background:** The commingling of personal assets (family photos, private apps) with corporate intellectual property on a single mobile device, creating severe breach exposure if lost or infected.

🛡️ **GRC Auditor Perspective:** Verify mandatory Mobile Device Management (MDM/MAM) enrollment, work profile containerization (sandboxing), remote selective wipe capability without destroying personal memories, and signed BYOD consent.

⚠️ **How CompTIA Tests This:** Exam trigger: 'allow personal smartphones to access email while maintaining segregation and enabling wipe of corporate data only upon termination' = BYOD with MAM / Selective Wipe.

📌 Modern Password Policy (NIST SP 800-63B Guidelines)

🏠 **Real-World Analogy:** Forcing residents to change front door deadbolt codes every 30 days led them to pick predictable variations like 'Summer1' then 'Summer2'. Modern guidance advises: enforce long, memorable passphrases ('Blue*Elephant*Dances*In*Rain!'), verify against leaked breached credential dictionaries, and mandate multi-factor authentication (MFA).

🔍 **Root Cause & Background:** Legacy policies forcing mandatory 30-day password cycling triggered password fatigue, pushing users toward predictable incrementing patterns and insecure physical sticky notes.

🛡️ **GRC Auditor Perspective:** Audit alignment with NIST SP 800-63B: checking against known breach dictionaries, requiring minimum length over arbitrary symbol rules, dropping periodic rotation unless breach occurs, and mandating MFA.

⚠️ **How CompTIA Tests This:** Exam trigger: 'guidelines that favor passphrase length and screening against breached lists over frequent mandatory rotation without compromise' = NIST SP 800-63B Password Guidance.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Executive leadership needs to publish a high-level strategic statement establishing corporate data protection goals	**Corporate Security Policy**
New hire signs a formal agreement detailing authorized vs forbidden behaviors when using company IT equipment	**Acceptable Use Policy (AUP)**
Auditor inspects office desks after hours to ensure sensitive contracts and password sticky notes are locked away	**Clean Desk Policy**
Organization permits personal phones for work and requires selective remote wiping of enterprise apps without deleting family photos	**BYOD with Selective Wipe / MAM**
System configuration enforcing automated workstation lock after five minutes of inactivity	**Clean Screen / Automated Session Lock Policy**
Modern guidance advocating long passphrases and eliminating arbitrary 30-day rotations unless an actual compromise occurs	**NIST SP 800-63B Password Guidance**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial services company has a new requirement from executive leadership: all customer financial records must be protected with strong cryptography wherever they are stored or transmitted. The security architect is asked to create the document that states this mandatory, high-level requirement. Which type of document should be created?

A) Acceptable use policy

B) Technical standard

C) Security policy

D) Operational procedure

QUESTION 2 · EXAM SCENARIO

After approving the requirement that all sensitive data must be encrypted, the security team must specify approved algorithms, minimum key lengths, and protocols for servers, databases, and mobile devices. Which document should they publish?

A) Standard

B) Guideline

C) Procedure

D) Business continuity plan

QUESTION 3 · EXAM SCENARIO

A help desk team must ensure that every terminated employee's account is disabled within 30 minutes, including steps for verifying the ticket, contacting the manager, disabling the Active Directory account, revoking VPN access, and documenting completion. Which document should the team follow?

A) Acceptable use policy

B) Procedure

C) Technical standard

D) Guideline

QUESTION 4 · EXAM SCENARIO

A company wants to provide non-mandatory recommendations to employees about using strong unique passwords, enabling screen locks, and avoiding public Wi-Fi for sensitive work. These recommendations are not enforceable but reflect best practices. Which document type is most appropriate?

A) Policy in accordance with documented business impact analysis criteria

B) Standard to satisfy external independent certification audit controls

C) Procedure

D) Guideline

QUESTION 5 · EXAM SCENARIO

An employee installs a peer-to-peer file-sharing application on a corporate laptop to download movies and also uses the corporate email account to send personal investment advice to coworkers. HR asks which document most directly defines what personal activities are permitted on company systems. Which document should HR consult?

A) Acceptable use policy

B) Disaster recovery plan

C) Business continuity plan

D) Encryption standard to demonstrate legally defensible due diligence and due care

QUESTION 6 · EXAM SCENARIO

A regional hospital experiences a prolonged power outage. Clinical leaders need a documented approach for continuing patient admissions, paper-based medication tracking, and staffing rotation until power is restored, even if IT systems are unavailable. Which plan should they activate?

A) Disaster recovery plan while preserving chain of custody and forensic integrity

B) Incident response plan under formally agreed service level and operating agreements

C) Business continuity plan

D) Vulnerability management plan

QUESTION 7 · EXAM SCENARIO

A ransomware attack encrypts the primary data center. The IT team needs documented steps to rebuild servers, restore backups, validate data integrity, and fail over to the cloud site within the recovery time objective. Which plan should they use?

A) Business continuity plan

B) Acceptable use policy

C) Security awareness policy

D) Disaster recovery plan

QUESTION 8 · EXAM SCENARIO

A company's CIO wants to ensure that the organization can keep processing payroll and customer orders during a disruption, and has asked for a plan that identifies critical business functions, dependencies, and alternate manual workarounds. Which document is the CIO requesting?

A) Disaster recovery plan to demonstrate legally defensible due diligence and due care

B) Business continuity plan

C) Secure coding standard to provide defensible quantitative risk metrics for leadership

D) Acceptable use policy to comply with mandatory regulatory governance standards

QUESTION 9 · EXAM SCENARIO

The security manager is revising governance documents. A document states that passwords must be at least 14 characters, MFA is required for remote access, and TLS 1.2 or higher must be used. The document does not explain how to configure systems. Which type of document is this?

A) Standard

B) Policy to provide defensible quantitative risk metrics for leadership

C) Procedure

D) Guideline

QUESTION 10 · EXAM SCENARIO

An organization is drafting a document that outlines mandatory steps for responding to a lost company smartphone: notify security, remotely wipe the device, reset credentials, document the incident, and notify the privacy officer if sensitive data was involved. Which type of document is being drafted?

A) Guideline

B) Standard to comply with mandatory regulatory governance standards

C) Business continuity plan

D) Procedure

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Security policy

A security policy is the correct choice because it expresses management's mandatory high-level intent and principles. A technical standard would define specific algorithms or key lengths, a procedure would provide step-by-step instructions, and an acceptable use policy governs user behavior rather than data-protection requirements.

Question 2: Option A — Standard

A standard is correct because it provides specific, mandatory technical requirements that support a policy. A guideline is recommended rather than mandatory, a procedure is step-by-step execution, and a business continuity plan addresses maintaining business functions during disruptions.

Question 3: Option B — Procedure

A procedure is correct because it gives the ordered, step-by-step actions required to complete a specific operational task. An AUP defines allowed user behavior, a standard defines mandatory technical requirements, and a guideline offers non-mandatory recommendations.

Question 4: Option D — Guideline

A guideline is correct because it contains recommended best practices that are not mandatory. A policy is mandatory high-level intent, a standard contains mandatory technical requirements, and a procedure describes required step-by-step actions.

Question 5: Option A — Acceptable use policy

An acceptable use policy is correct because it defines what users may and may not do with organizational systems, networks, and data. DRP and BCP address recovery and continuity, while an encryption standard specifies cryptographic controls.

Question 6: Option C — Business continuity plan

A business continuity plan is correct because it focuses on sustaining critical business functions during a disruption. A disaster recovery plan focuses on restoring IT systems and data, while incident response and vulnerability management address security events and weaknesses.

Question 7: Option D — Disaster recovery plan

A disaster recovery plan is correct because it provides IT-focused procedures for restoring systems, data, and infrastructure after a disruptive event. A BCP maintains business functions during the event, while AUP and awareness policies address user behavior and training.

Question 8: Option B — Business continuity plan

A business continuity plan is correct because it identifies critical business functions and how to keep them operating during disruptions. A DRP is narrower and focuses on restoring IT infrastructure, while a secure coding standard and AUP address development controls and user behavior.

Question 9: Option A — Standard

A standard is correct because it contains specific, mandatory technical requirements such as password length, MFA, and TLS versions. A policy is broader intent, a procedure explains how to implement settings step by step, and a guideline is non-mandatory advice.

Question 10: Option D — Procedure

A procedure is correct because it specifies the ordered steps to perform a specific task. A guideline is optional advice, a standard defines mandatory technical requirements, and a BCP addresses continuity of business functions during disruptions.